

REDES Y SEGURIDAD 2

PRÁCTICA 1.2



JOHNNY: Conocí a un Sánchez. Regentaba uno de los mejores tugurios de la ciudad, con un café que te disolvía el cromo de lo caliente que estaba... Pero ¿sabes qué? Nadie se colaba en su barra. Tenía ojos en todas partes. Igual que un buen firewall: vigilante, paranoico, y listo para cerrarte el paso si no dices las palabras mágicas. Hoy toca jugar al portero. O al intruso. Tú eliges.

En esta práctica aprenderás a:

- Usar el escáner de puertos **nmap**.
- Configurar un firewall con **iptables** en dos tipos de despliegues.



Esta práctica consta de dos escenarios diferentes.

No pases al segundo hasta no haber completado el primero.

CHAMBA: P12-Firewall_1

192.168.2.2

ARASAKA



192.168.2.42

NETRUNNER



Las máquinas (**arasaka** y **netrunner**) ya tienen su IP asignada y están listas para trabajar sobre ellas.

ESCANEO CON NMAP

NETRUNNER

El escáner de puertos empleado es **nmap**, el cual tiene numerosas opciones.

El objetivo será siempre **arasaka**.

1. Realizar un escaneo con las opciones por defecto.
2. Escanear el rango de puertos 21-25 y 80-139 en el mismo comando.

NETRUNNER

3. Realizar un escaneo UDP del mismo rango de puertos de antes.
4. Detectar el sistema operativo del objetivo.
5. Realizar el escaneo completo que incluye detección del sistema operativo, versión de los servicios y trazado de ruta.

FIREWALL CON IPTABLES

El firewall elegido es **iptables**, el cual actúa a nivel del kernel de Linux. Se configura introduciendo reglas de filtrado que afectan a tres categorías principales llamadas cadenas:

- **INPUT**: paquetes de entrada.
- **OUTPUT**: paquetes de salida.
- **FORWARD**: paquetes que atraviesan la máquina de una interfaz de red a otra (sólo aplicable a routers).



No obstante, se puede definir una política por defecto a través de la opción **-P**, para luego concretar con las siguientes reglas:

- **ACCEPT**: acepta todos los paquetes.

- **DROP**: rechaza todos los paquetes.

De esta manera, la regla más habitual en una máquina segura, rechazar todos los paquetes, se definiría de la siguiente manera:

iptables -P INPUT DROP

iptables -P OUTPUT DROP

iptables -P FORWARD DROP

(No ejecutar esto todavía)

A partir de aquí se van añadiendo reglas usando la opción **-A** **<CADENA>**, para a continuación, indicar los criterios.

Algunos de estos criterios son:

- Dirección IP de origen y destino: **-s** y **-d**, respectivamente.
- Protocolo: **-p tcp/udp/icmp**.
- Puerto de origen y destino (aplicable a TCP/UDP): **--sport** y **--dport**, respectivamente.
- Número de código de mensaje ICMP: **--icmp_type**
- Interfaz de entrada y salida: **-i** y **-o**.
- Estado de la conexión: **-m state --state <ESTADO>**, pudiendo estar el ESTADO separado por comas.
 - **NEW**: conexiones nuevas.
 - **ESTABLISHED**: conexiones ya establecidas.
 - **RELATED**: paquetes relacionados con conexiones ya existentes.
 - **INVALID**: paquetes que no pertenecen a las anteriores categorías.

Y por último hay que indicar la acción a realizar por iptables para la regla introducida. Esto se realiza con la opción **-j** seguida de **ACCEPT** o **DROP**.

Las reglas del firewall pueden ser visualizadas con **-L** y pueden ser borradas completamente con **-F**.



Lo más cómodo es crear un script bash en la máquina donde se ejecuta el cortafuegos.

Éste debería comenzar con el comando **iptables -F** , el cual borra totalmente la configuración actual. A continuación se irán introduciendo el resto de llamadas a **iptables** con la configuración deseada.

A este script se le darán permisos de ejecución (comando **chmod**) y se ejecutará cada vez que se quiera probar un cambio introducido.

NMAP VS. IPTABLES

A continuación se probarán diversos tipos de escaneo con nmap y se mostrará su contramedida mediante **iptables**.

NETRUNNER

Se capturará el tráfico con **tshark** para poder entender los diferentes tipos de escaneos realizados.

La mecánica es la siguiente:

1. Realizar el escaneo indicado con **nmap** desde **netrunner**.
2. Aplicar la(s) regla(s) al firewall de **arasaka**.
3. Volver a repetir el escaneo desde **netrunner** para probar la efectividad de la(s) regla(s) introducidas.
4. Mientras haya un tipo de escaneo por realizar, **GOTO 1**.

NETRUNNER y ARASAKA

Escaneo: TCP Null

Firewall:

iptables -A INPUT -p tcp --tcp-flags ALL NONE -j DROP



¿En qué consiste este escaneo?

NETRUNNER y ARASAKA

Escaneo: TCP Xmas

Firewall:

iptables -A INPUT -p tcp --tcp-flags ALL FIN,PSH,URG -j DROP



¿En qué consiste este escaneo?

¿Es éste el único tipo de escaneo TCP Xmas que existe?

NETRUNNER y ARASAKA

Escaneo: TCP FIN

Firewall:

iptables -A INPUT -p tcp --tcp-flags ALL FIN -j DROP



¿En qué consiste este escaneo?

NETRUNNER y ARASAKA

Escaneo: TCP SYN

Firewall:

NETRUNNER y ARASAKA

iptables -A INPUT -p tcp --syn -m limit --limit 1/s --limit-burst 4 -j ACCEPT

iptables -A INPUT -p tcp --syn -j DROP

NOTA: Interrumpir el escaneo tras esperar un tiempo.



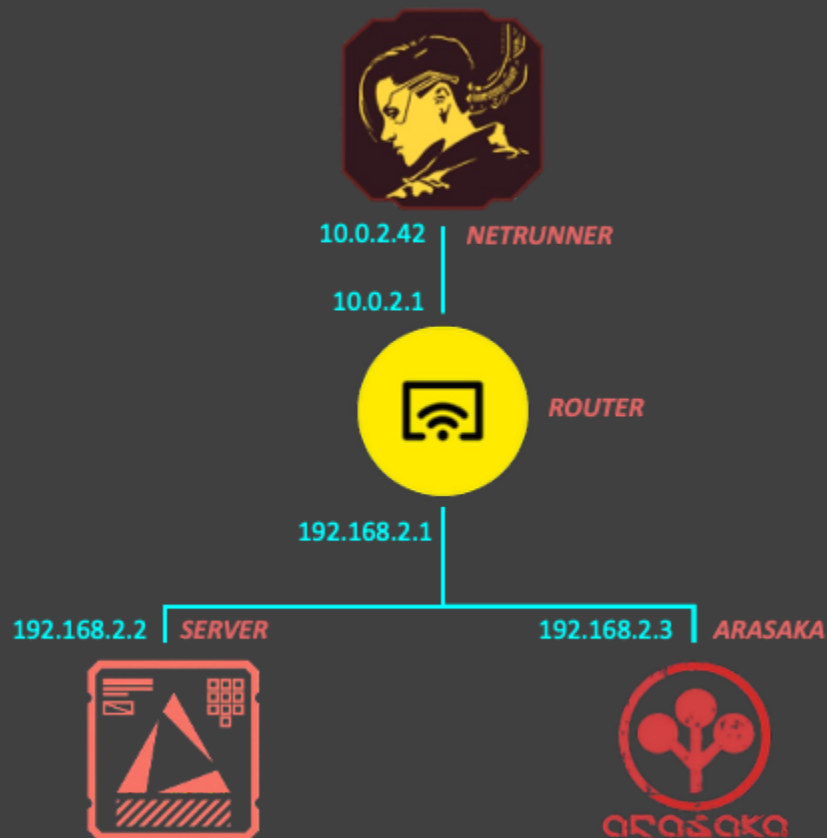
¿En qué consiste este escaneo?

¿Cuál es la dificultad a la hora de bloquear este escaneo?

¿Cuál es la respuesta de nmap cuando detecta la contramedida de iptables?

¿Qué contramedida se podría aplicar a la respuesta de nmap?

CHAMBA: P12-Firewall_2



La máquina **netrunner** deberá añadir con **ip route** una ruta a la red 192.168.2.0/24, indicando la IP del **router** que está en su propia red. Por su parte, **server** y **arasaka** harán lo mismo, pero con la red 10.0.2.0/24.

CONFIGURACIÓN DEL CORTAFUEGOS

ROUTER

El firewall debe tener las siguientes reglas:

- **DROP** por defecto en todas las cadenas.
- Permite en todas las cadenas conexiones omnidireccionales ya establecidas y paquetes relacionados.
- Permite conexiones nuevas SSH (puerto de destino 22) entre ambas redes.
- Permite conexiones nuevas de cualquier protocolo desde la red interna.
- En el contexto de una herramienta de monitorización desactualizada, permite conexiones nuevas desde el puerto 288 (TCP y UDP) de cualquier máquina de la red externa a cualquiera de la red interna.

IMPORTANTE: Al ser un router, será necesario usar la cadena **FORWARD**.

SERVER

Arrancar tanto el servidor SSH como el servidor IRC con el comando **service**.

ARASAKA

El firewall debe tener las siguientes reglas:

- **DROP** por defecto en todas las cadenas menos la de salida.
- Permite en todas las cadenas conexiones omnidireccionales ya establecidas y paquetes relacionados.
- Sólo permite conexiones entrantes nuevas desde **server**.

Estas son algunas de las pruebas que se pueden realizar para verificar la configuración del escenario:

1. No se puede hacer ping desde **netrunner** al resto de máquinas pero sí viceversa.
2. Sólo se puede hacer ping a **arasaka** desde **server**.
3. Se puede hacer ssh desde **netrunner** a **server**.

ESCANEO DESDE EL EXTERIOR

NETRUNNER

Escanear todo el rango de IPs de la red 192.168.2.0/24 usando la opción de escaneo TCP SYN.

Se recomienda usar además la opción **-vv**.



¿Cuál es el resultado? ¿Por qué?

NETRUNNER

Realizar nuevamente el escaneo, añadiendo la opción **-Pn**.



¿Cuál es el resultado?

¿Para qué sirve esta nueva opción?

Es el momento de utilizar la vulnerabilidad dejada en **router** para acomodar a la herramienta de monitorización desactualizada.

NETRUNNER

Realizar el escaneo indicando que el puerto de origen sea el 288.



¿Qué máquinas son las encontradas? ¿Por qué?

A este punto, está claro que desde la red actual no se podrá acceder a la máquina objetivo (**arasaka**).

Pero por otro lado, se ha descubierto una máquina (**server**), que puede usarse como "cabeza de playa" para continuar.

ESCANEAO A TRAVÉS DE PROXY

SERVER

Apagar el servidor SSH usando el comando **service**.

Arrancar un servidor proxy de tipo **http** en el puerto 22 usando la herramienta **ncat**.



¿Por qué hay que apagar el servidor ssh?

NETRUNNER

Editar **/etc/proxychains4.conf**, cambiando la última entrada por:

http 192.168.2.2 22

Ejecutar **proxychains** seguido de **nmap** indicando las siguientes opciones:

- Objetivo: **arasaka**.
- Tipo de escaneo: TCP Connect().
- No hacer ping.



¿Por qué esta vez no ha sido necesario indicar el puerto de origen en el escaneo?

Como se ha encontrado el puerto 80 abierto en **arasaka**, revelando un servidor web, se procederá a conectarse a él usando un navegador.

NETRUNNER

Se usará el navegador web desde terminal **w3m**.

1. Conectarse a **arasaka** usando **proxychains**

> **proxychains w3m URL**

2. Conectarse a ARASAKA indicando el servidor proxy como opción:

> **w3m -o HTTP_PROXY="SERVIDOR:PUERTO" URL**



Puedes salir de **w3m** pulsando la tecla **q**.

_ EOL